الجامعة اللبنانية
UNIVERSITE LIBANAISE

IN410
Cryptography and Secure Communications

Ahmad Fadlallah

Course Syllabus

- Context
- History/ Classical ciphers
- Symmetric Encryption
- Cryptographic hash functions
- <u>Key Exchange & Public Key Cryptography</u>
- Authentication

Credits

- The following slides are the adaptation of
  - Lecture slides of Lawrie Brown based on William Stallings book “Cryptography and Network Security: Principles and Practice”
  - Lecture Slides of Dan Boneh – Stanford University
  - Lecture slides of Pawel Wocjan – University of Central California
  - Lecture Slides of Ahmed Serhrouchni – Telecom ParisTech
  - Others (References in the note section)

X.509 CERTIFICATES

Motivations

- Asymmetric cryptography is used for:
  - Evidence-oriented services
  - Distribution of session keys
  - Longer service life
    - Need to revoke them if necessary

Motivations (cont'd)

- Problem of Asymmetric cryptography
  - The distribution of public keys
  - Public Key Authentication
    - A public key belongs to the one who claims to be the holder
  - The use associated to the public key
- The answer is the **certificate** and associated infrastructure for their management

Motivations

- "Certificate" = belongs to an authority or institution
- The content = "Authentic" Information
- Dictionary: « an official document attesting a fact » (Oxford Dict.)
- Presence of a "recognized" authority attesting to the veracity of the content.
- Certificate = "signed" Document

Objective & Applications

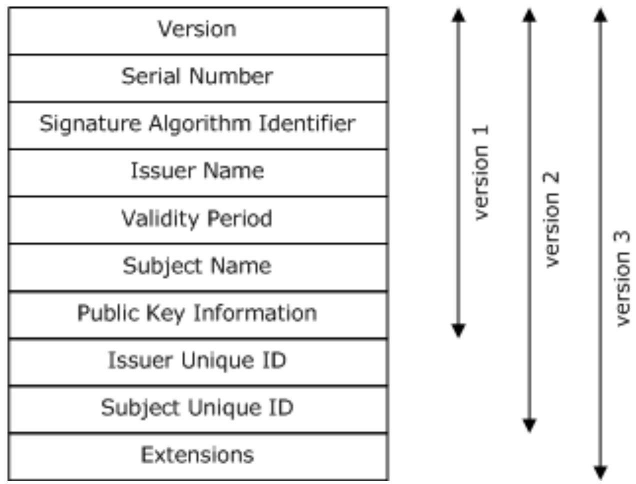
- **<u>Main Objective:</u>** link *identity* and *public key* through the signature of a trusted third party
- Applications
  - Personal certificate => to authenticate a user.
  - Server Certificate => to authenticate a server
  - Developer certificate => sign/authenticate the developed programs and macros.
  - Certificate of Certification Authority => sign certificates

X.509 Certificate - Definition

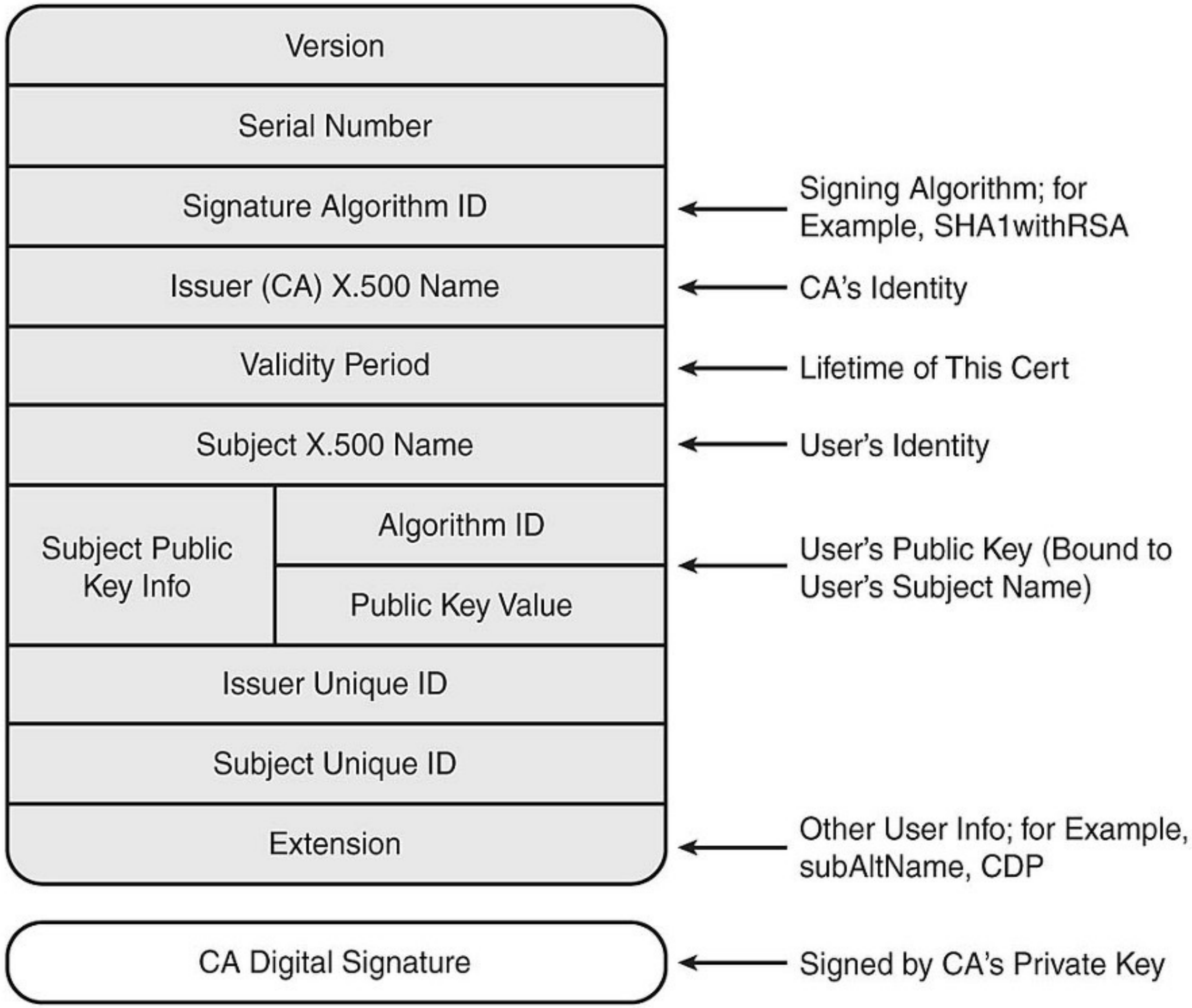
- Data structure for linking various elements by means of a signature of a Certification Authority (CA)
  - The subject, the key, the certificate issuer, validity conditions, ...

X.509 Certificates

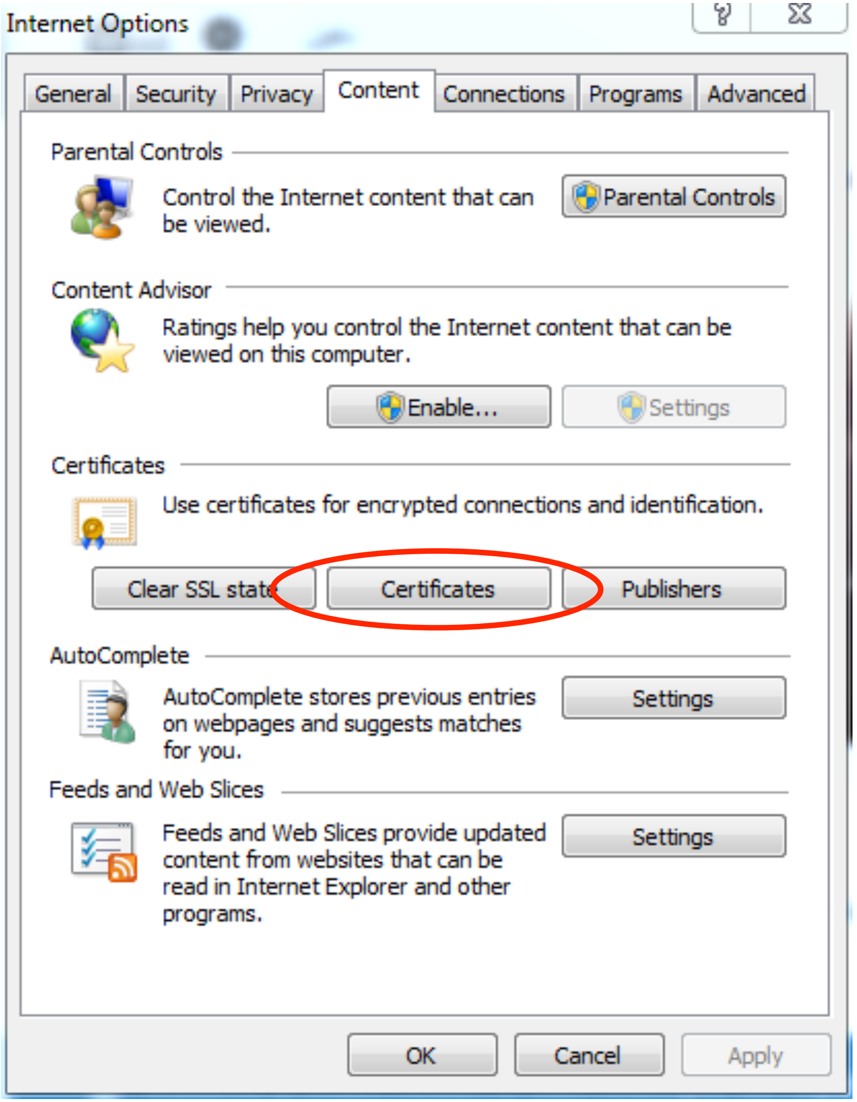
- Standard
  - ITU-T X.509(03/2000), or ISO/IEC 9594-8
    - Public Key and Attribute Certificates
  - [RFC 5280: Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile]
- Versions:
  - 1988 : v1
  - 1993 : v2 = v1 + 2 new fields
  - 1996 : v3 = v2 + extensions

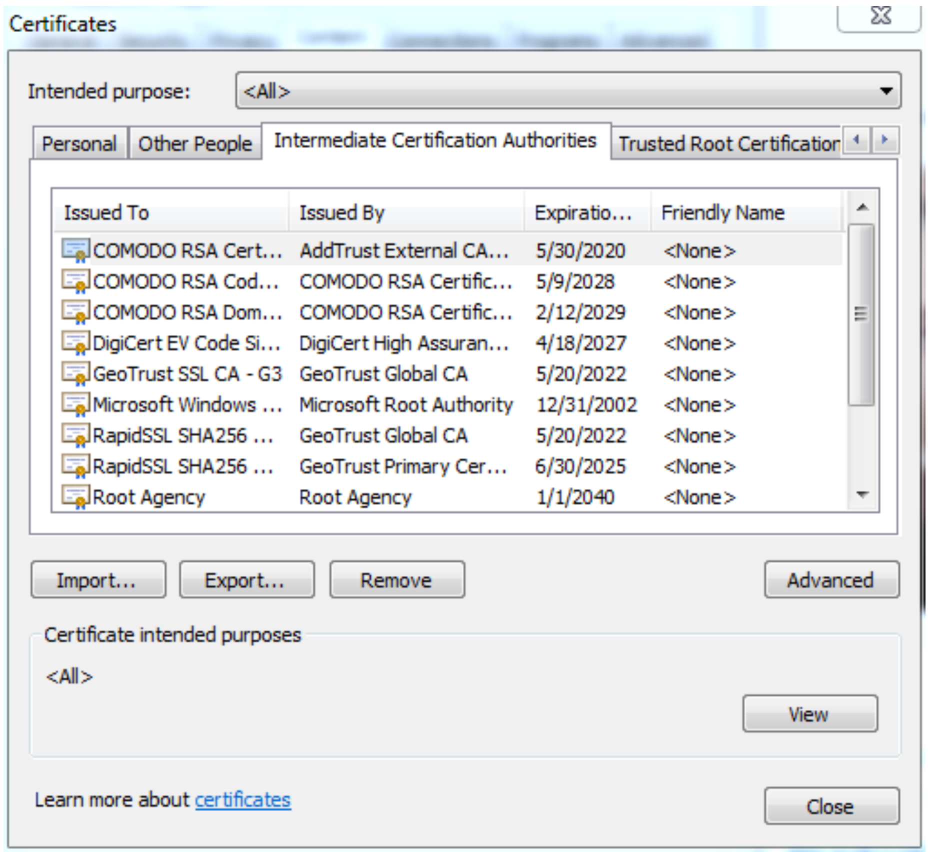


X.509 Certificates

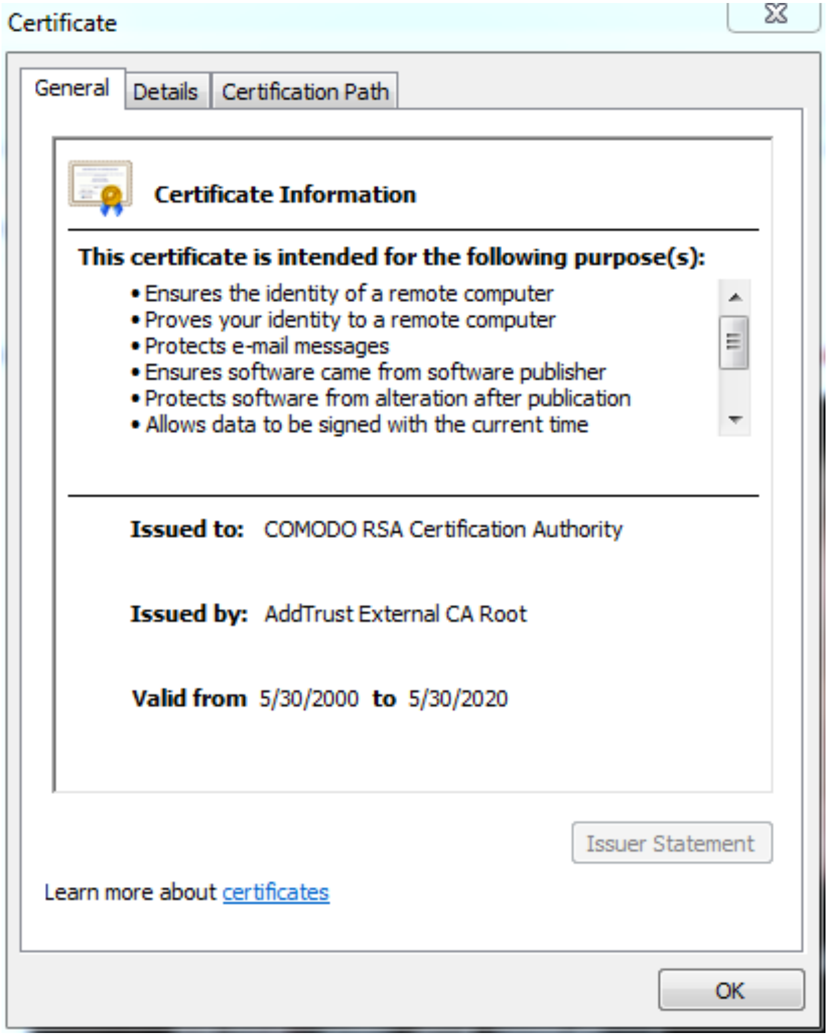


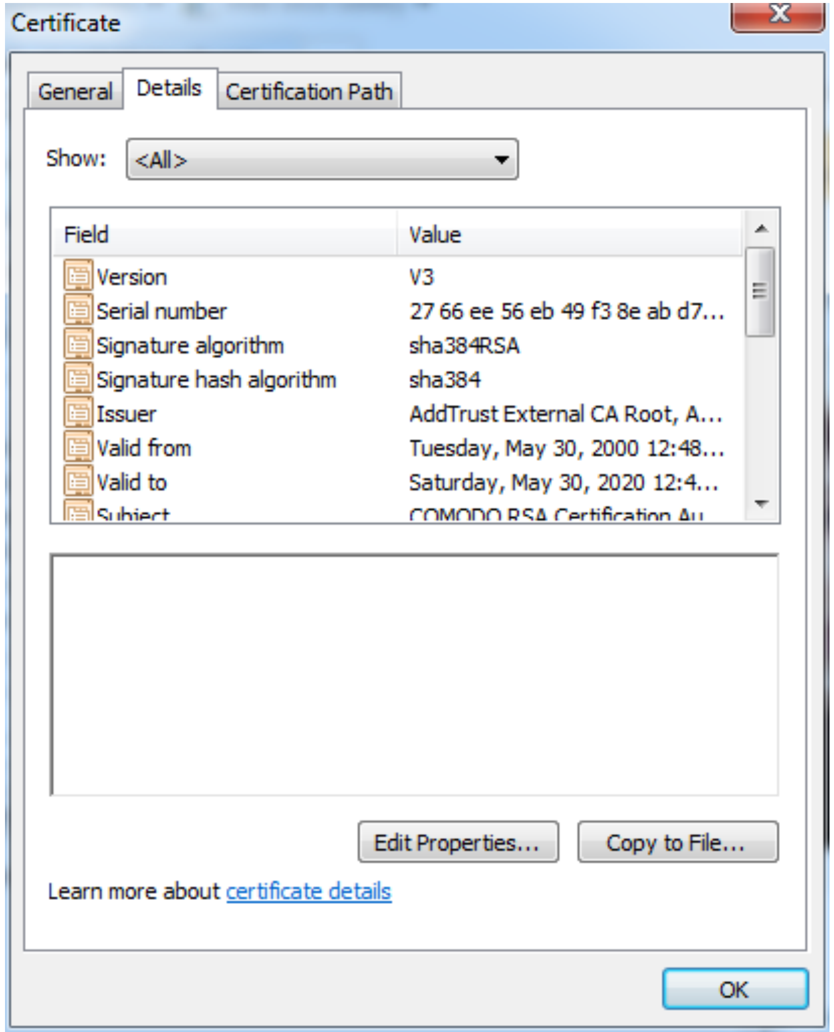
X.509 Certificate - Example



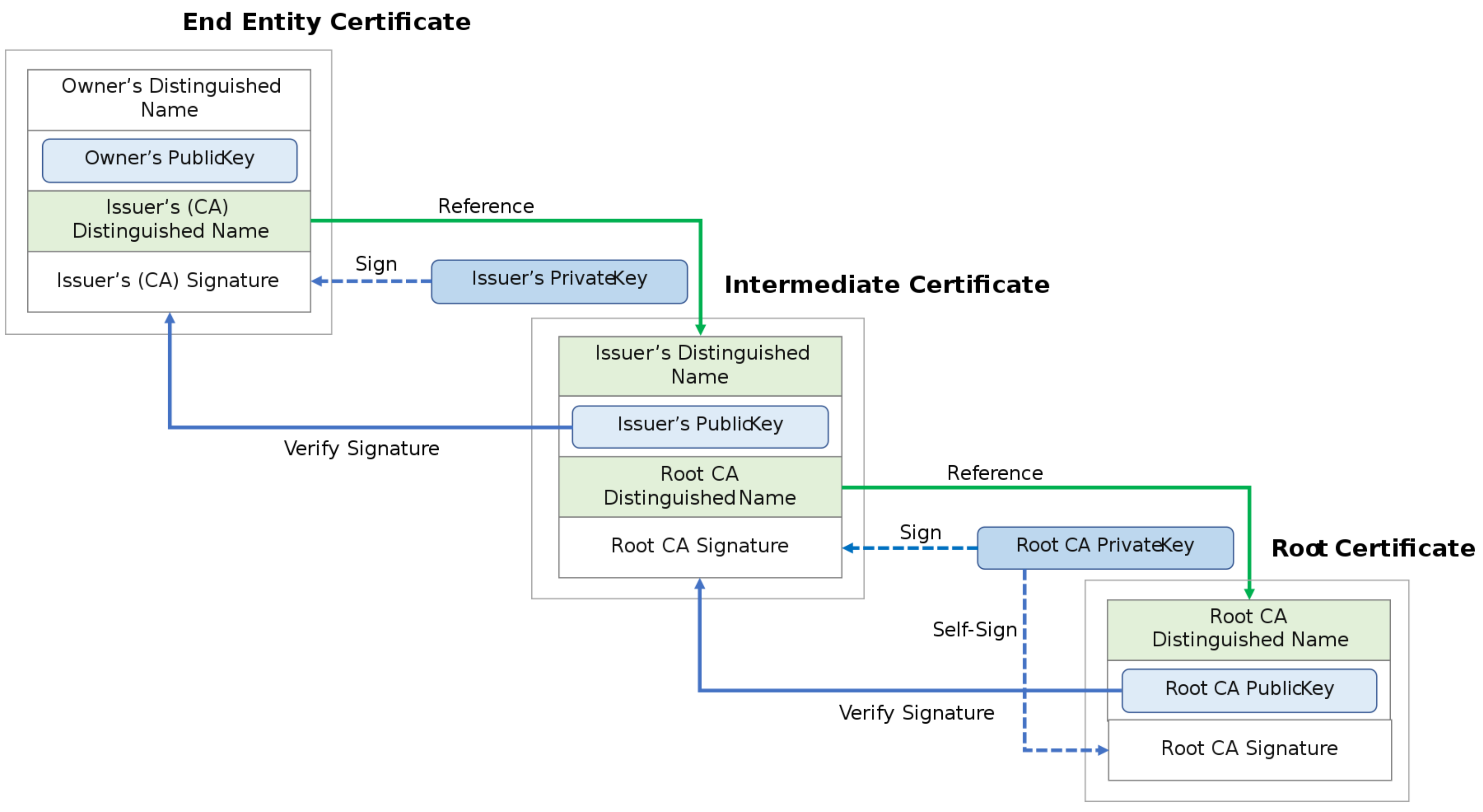


X.509 Certificate - Example





Certificate Chain of Trust



Extensions

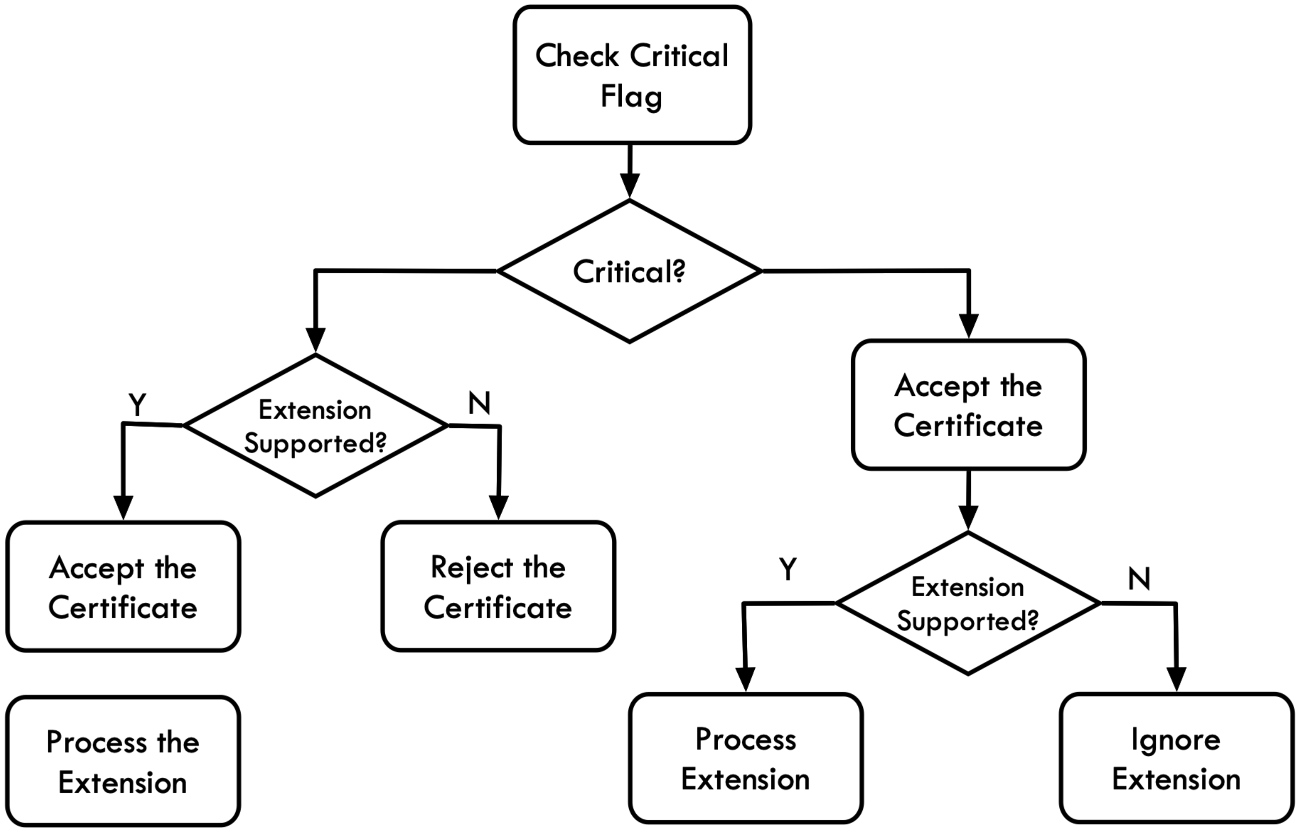
- The initial goal of certificates is to link identity and public key through the signature of a trusted third party
- **To cover wider services**
  - Need to associate additional information with the public key
- **The extension is to add new fields to certificates**
- Extensions are standardized in general
  - *Possibility to define specific extensions*
- If the application does not support a critical extension, it « drops » the certificate.

Extensions

- Extension structure

Extension Type	Critical Flag (0 or 1)	Value

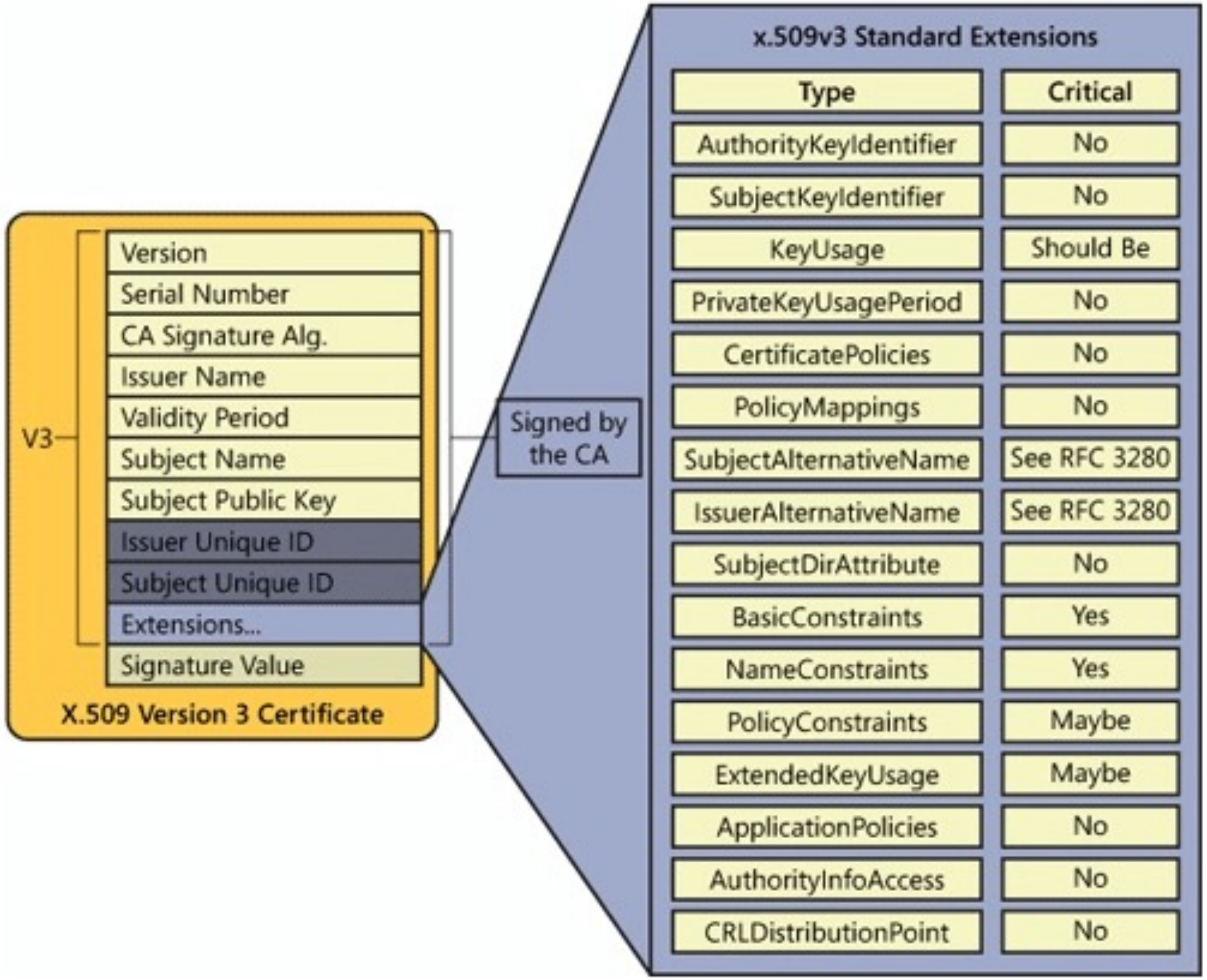
- Type is unique for each extension



Extensions

- Extensions:
  - Naming the subject and signer (issuer)
  - Public / private keys
  - Revocation
  - Certification Policy
  - Roles
  - More ... logo, …

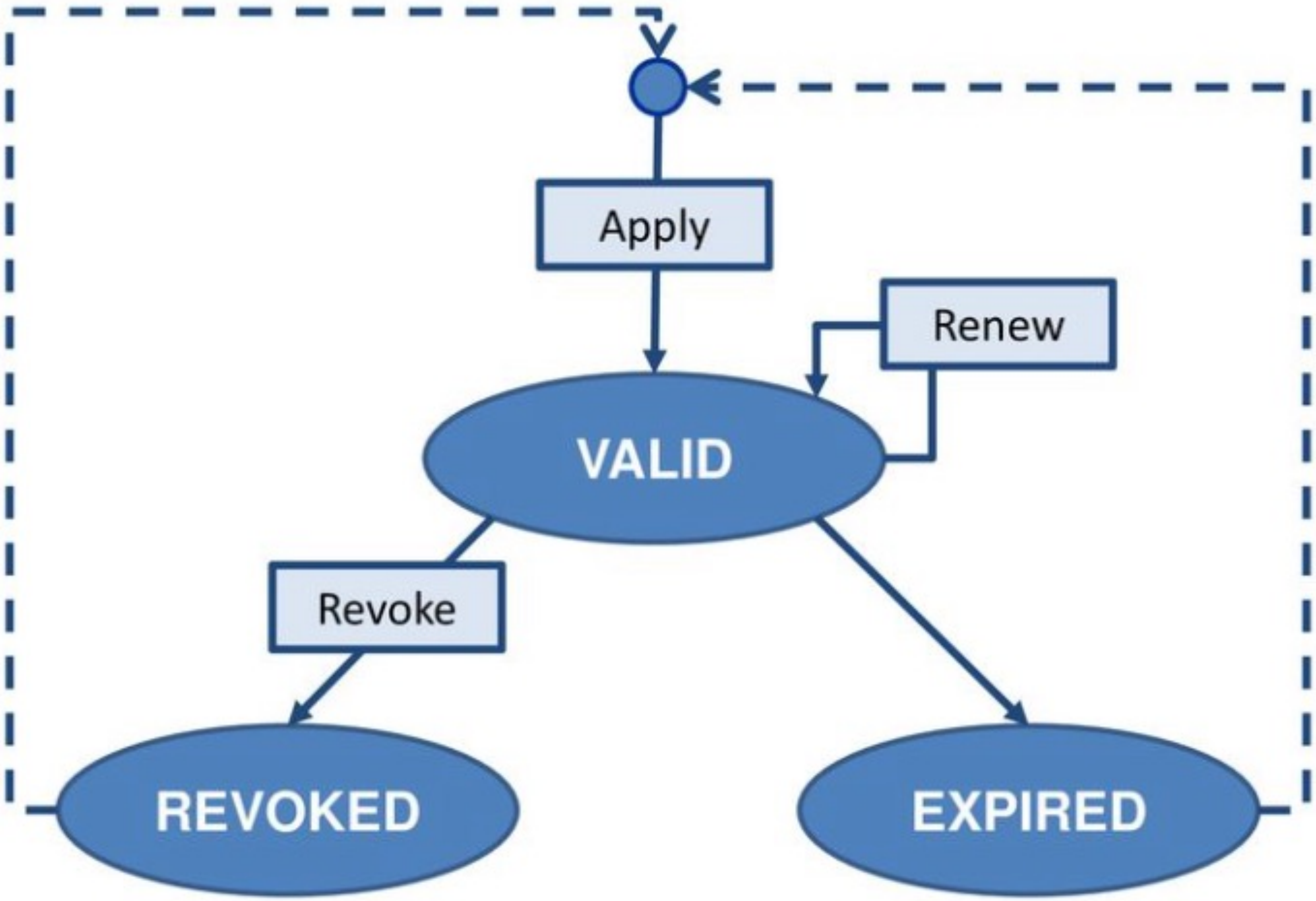
Extensions


Version
Serial Number
CA Signature Alg.
Issuer Name
Validity Period
Subject Name
Subject Public Key
Issuer Unique ID
Subject Unique ID
Extensions...
Signature Value
V3
X.509 Version 3 Certificate
Signed by the CA
x.509v3 Standard Extensions
Type
Critical
AuthorityKeyIdentifier
No
SubjectKeyIdentifier
No
KeyUsage
Should Be
PrivateKeyUsagePeriod
No
CertificatePolicies
No
PolicyMappings
No
SubjectAlternativeName
See RFC 3280
IssuerAlternativeName
See RFC 3280
SubjectDirAttribute
No
BasicConstraints
Yes
NameConstraints
Yes
PolicyConstraints
Maybe
ExtendedKeyUsage
Maybe
ApplicationPolicies
No
AuthorityInfoAccess
No
CRLDistributionPoint
No

Extensions - Most Common

- **Basic Constraints**
  - used to indicate whether the certificate belongs to a CA.
- **Key Usage**
  - Specify the cryptographic operations which may be performed using the public key contained in the certificate
  - Example: *Encryption only*
- **Extended Key Usage**
  - Typically on a <u>leaf certificate</u>
  - Indicate the purpose of the public key of the certificate
  - Example: SSL Server, Secure email.

Certificate Lifecycle



Revocation

- A **certificate can be revoked** if:
  - Authority's private key is compromised
  - Private key associated with certificate is compromised
  - Change in status of the certificate holder
  - Suspension of the certificate holder
  - Certificate was obtained by fraud
  - …
- The **authority of revocation** and the **certification authority** may be the same entity

Revocation

- Different methods of revocation:
  - CRLs (Certificate Revocation List)
  - CRL Distribution Points
  - Delta CRLs
  - OCSP (Online Certificate Status Protocol)
- A certificate includes an extension that indicate the supported revocation method(s)

Revocation - CRL

- Certificate Revocation List (CRL)
  - Traditional model, <u>supported by all platforms</u>.
  - Blacklist of revoked certificates.
  - Signed by the certification authority and published in a directory
- Each entry contains:
  - Certificate serial number
  - Date of revocation
  - Other information as the reason of revocation
  - …

Revocation - CRL: Pros. & Cons.

- Advantages
  - Simple
  - Compatible with applications
- Disadvantages
  - Revocation server must periodically publish a new CRL
    - Even if no certificate was revoked since last CRL
  - Size of the CRL can significantly increase
    - Overhead in communication, processing and storage
  - Expiry at the same date of the CRL

Revocation - CRL Distribution Points

- Principle: divide the CRL into smaller parts
- Each certificate contains information that allows the application to check its validity in the right place
- Advantages
  - Solves the CRL increasing size problem
- Disadvantages
  - Certification verification place is hard-coded in the certificate
  - Introduces implementation complexity

Revocation - Delta CRL

- Provides information about certificates whose status has changed since the last CRL.
- Reduces the amount of data to be exchanged with the Revocation Authority
- Delta CRL is associated with a reference CRL

Revocation - OCSP

- OCSP: Online Certificate Status Protocol
  - RFC 2560
  - Enables real-time verification of the validity of the certificate
  - Based on a client-server model (Request / Response)
    - The OCSP server can use the CRL to respond
- The application hosts a client that queries the OCSP server on the status of the certificate
  - Server sends the status of the certificate in a signed message

Revocation - OCSP (Cont’d)

- Advantages
  - Provides up-to-date information
  - Fast response time
- Limitations
  - OCSP server has to sign all the responses
  - OCSP server private key should be highly secured (additional cost)
  - Needs high availability of server and service

PUBLIC KEY INFRASTRUCTURE (PKI)

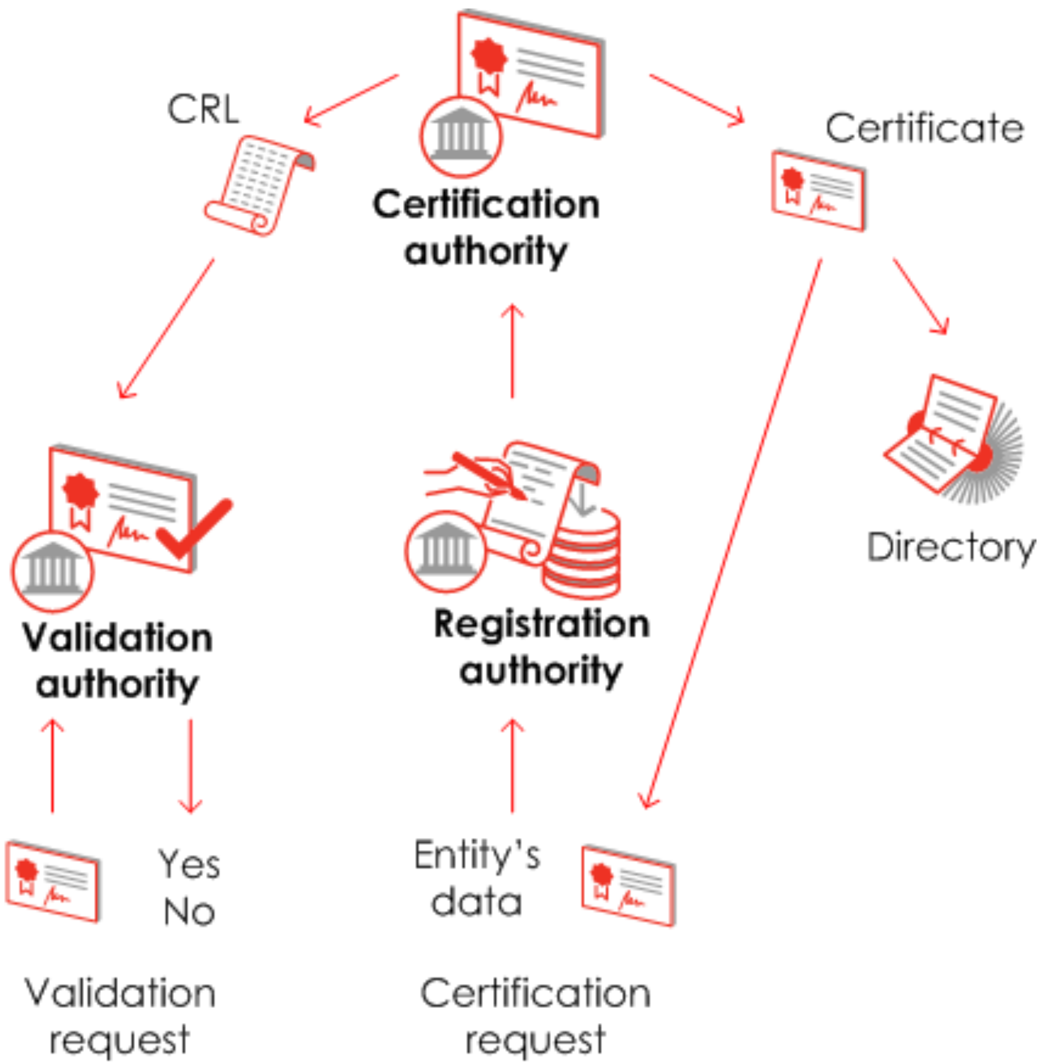
Definition

"A public-key infrastructure (PKI) is the set of hardware, software, people, policies, and procedures needed to create, manage, store, distribute, and revoke digital certificates based on asymmetric cryptography.

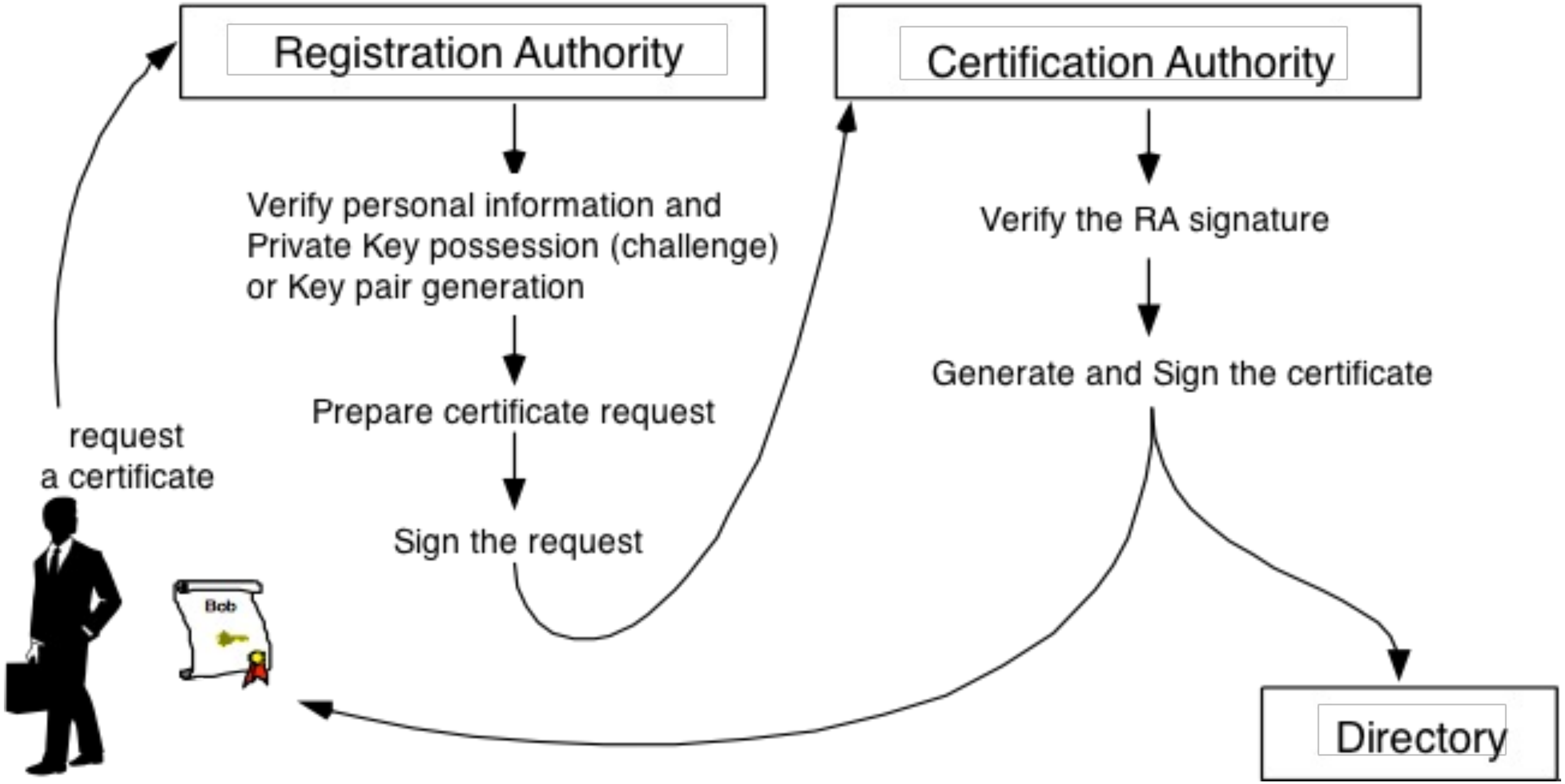
Its principal is to enable secure, convenient, and efficient acquisition of public keys"

(RFC 2822 - Internet Security Glossary)

PKI Simplified Architecture



Certificate Generation Process



Base64 Format

Base64 Encoding

- Based on an alphabet of 64 symbols
  ABCDEFGHIJKLMNOPQRSTUVWXYZ
  abcdefghijklmnopqrstuvwxyz
  0123456789 + /
- A block of 24 bit divided into 6-bit block
  - A 6-bit block corresponds to a symbol of the alphabet base64
  - Padding with "=" to achieve 24-bit
  - 76 symbols per line (LF character at the end of line)

Base64 Encoding

Text content	M	a	n
ASCII	77 (0x4d)	97 (0x61)	110 (0x6e)
Bit pattern	0 1 0 0 1 1 0 1	0 1 1 0 0 0 0 1	0 1 1 0 1 1 1 0

Index	19	22	5	46
Base64-encoded	T	W	F	u

Value	Char	Value	Char	Value	Char	Value	Char
0	A	16	Q	32	g	48	w
1	B	17	R	33	h	49	x
2	C	18	S	34	i	50	y
3	D	19	T	35	j	51	z
4	E	20	U	36	k	52	0
5	F	21	V	37	l	53	1
6	G	22	W	38	m	54	2
7	H	23	X	39	n	55	3
8	I	24	Y	40	o	56	4
9	J	25	Z	41	p	57	5
10	K	26	a	42	q	58	6
11	L	27	b	43	r	59	7
12	M	28	c	44	s	60	8
13	N	29	d	45	t	61	9
14	O	30	e	46	u	62	+
15	P	31	f	47	v	63	/

Base64 Encoding


```
-----BEGIN RSA PRIVATE KEY-----
MIICXQIBAAKBgQCauoGr1KOcfwtzMy/jUeXV86WVh33NEoGro6+7+Yj36wizrP++
57QRht4q44N8lJKEsdEUZbtNKo0Gb5I9EXWNDbDsc5KuqiaIpbszj2x6faJExZdE
l3tbRCyKMzJwf0JxjJM+qWnh4t+6dLoM0IdnnX9v97aLxSuPGdYFJSAxQQIDAQAB
AoGAcp5emI94c+GY9cmhW9+7Rnaq3s3z3woqjJ9A+xqq4Bx34cHx4dV6itFBmrvX
F15n+2xN2bJSwaMXvQDBcAOS87eilV3LPesBgmllWBn7frPafKgkM9GjqZOf0617
IJqACq0oMd/bpjwMgYeI+mLckKv0d0+aASFaZEIFh+jhisECQQDJGWrJFZkkiXss
BJW7XIxx5tVUMlpIng4WNOl53bW5X78Kyr04unlQoSiqTT0LdisSELE5scIbEiBp
C/xkrmRlAkEAxPhLei763sZNWXFs1X+nQ0M0ieuXXM8x2O+YYrBtzDshzlAX72FF
TmATwz2IelePuxiAadpC6F30GUBEyhjlrQJBAJ2Tbgp9AxAPLlXSjeVPYrmJsBWW
kwod11ntQhl88f18mf0B2f2OmKrmbS/s7+2APcWdENHtiPSfYogNnUrjH8UCQQCK
RFYPdi0q9v9TOzkQAiUzJVkbPCMrxlKSm1ZYaMsao6POhRDYPGr/Yphc5LQKVa8S
wldadxmirlls5F2llKadAkBQXCiuSqimmrXMkqM/BT5eqixwAgNDY6UycbgyG17b
E4GSMx6X+xesblszwvUi76AH0RDQAAwweeDV/OkZlTT+
-----END RSA PRIVATE KEY-----
```